

CYBERSECURITY RISK ASSESSMENT REPORT

BrightPay Financial

NIST Cybersecurity Framework 2.0
Enterprise Risk Assessment

PREPARED BY: Prayash Bhattarai, Cybersecurity Analyst

DATE: March 2026

CLASSIFICATION: Confidential — Internal Use Only

FRAMEWORK: NIST Cybersecurity Framework (CSF) 2.0

VERSION: 1.0

Purpose of this document: This risk assessment evaluates the cybersecurity posture of BrightPay Financial against the NIST CSF 2.0 framework. It identifies key risks, documents existing controls, performs a gap analysis, and provides prioritized remediation recommendations to strengthen the organization's security program.

1. Executive Summary

BrightPay Financial faces significant cybersecurity risks across its payment processing infrastructure, customer data systems, and employee-facing technology. This assessment was conducted using the NIST Cybersecurity Framework (CSF) 2.0 and identifies 15 key risks across the organization's technology environment.

Of the 15 risks assessed, **3 are rated HIGH (score 15-20)**, **8 are rated MEDIUM (score 10-14)**, and **4 are rated LOW (score below 10)**. The highest risk areas involve the customer database, payment processing system, and data in transit — all of which directly impact customer financial data and regulatory compliance.

Key Findings

Critical Gap: BrightPay lacks Multi-Factor Authentication (MFA) across its payment processing systems and admin accounts. This represents the single highest-priority remediation item and should be addressed within 30 days.

Critical Gap: No formal Privileged Access Management (PAM) program exists. Admin accounts operate with standing privileges, creating significant risk of privilege escalation and insider threat.

Moderate Gap: Incident detection capabilities are limited to manual monitoring. A SIEM solution is required to provide automated threat detection and alerting aligned to NIST Detect function requirements.

Moderate Gap: Third-party vendor risk is unmanaged. No formal vendor security assessment process exists despite BrightPay's reliance on multiple payment processing partners.

Recommendations Summary

This report recommends a phased approach to remediation organized into three priority tiers. Immediate actions (0-30 days) focus on MFA deployment and access control hardening. Short-term actions (30-90 days) address SIEM implementation and vendor risk management. Long-term actions (90+ days) build toward a mature compliance and governance program.

Full implementation of these recommendations would significantly improve BrightPay's security posture and position the organization for regulatory compliance with applicable financial services standards including PCI-DSS and applicable state regulations.

2. Company Overview

BrightPay Financial is a fictional small financial technology (fintech) company used for the purposes of this risk assessment exercise. The organization profile is designed to reflect a realistic early-stage fintech operating in the United States payments space.

Attribute	Details
Organization	BrightPay Financial
Industry	Financial Technology (Fintech) — Payments Processing
Employees	50 employees across Engineering, Finance, HR, and Operations
Infrastructure	Hybrid cloud (Microsoft Azure + on-premises servers)
Key Systems	Payment processing platform, customer database, employee laptops, API endpoints, cloud storage, email
Regulatory Context	Subject to PCI-DSS (payment card data), GLBA (financial data), applicable state privacy laws
Current Security Maturity	Low-to-Moderate — basic controls in place, no formal security program

As a payments processor, BrightPay handles sensitive customer financial data and is subject to strict regulatory requirements. A breach or compliance failure could result in significant financial penalties, reputational damage, and loss of payment processing licenses.

3. Assessment Methodology

This risk assessment was conducted using the **NIST Cybersecurity Framework (CSF) 2.0**, which organizes cybersecurity activities into six core functions:

Function	Description
Govern	Establish and monitor the organization's cybersecurity risk management strategy, policies, and oversight
Identify	Understand organizational assets, risks, and vulnerabilities that could impact the delivery of services
Protect	Implement safeguards to limit the impact of cybersecurity events on critical systems and data
Detect	Develop and implement activities to identify the occurrence of cybersecurity events in a timely manner
Respond	Take action regarding a detected cybersecurity incident to contain its impact
Recover	Maintain resilience and restore capabilities impaired due to a cybersecurity incident

Risk Scoring

Each risk was scored using a standard likelihood × impact matrix:

Risk Score = Likelihood (1-5) × Impact (1-5)
High Risk: Score 15–25 | Medium Risk: Score 8–14 | Low Risk: Score 1–7

4. Risk Register

The following table documents all 15 identified risks for BrightPay Financial, including likelihood, impact, risk score, current controls, and recommended controls.

ID	Asset	Threat	L	I	Score	Current Control	Recommended Control	NIST Function
R001	Customer Database	SQL Injection	4	5	20	Basic input validation	Parameterized queries, WAF	Protect
R002	Payment Processing	Unauthorized Access	3	5	15	Password auth only	MFA, RBAC	Protect
R003	Employee Laptops	Malware/Ransomware	4	4	16	Basic antivirus	EDR, regular patching	Protect
R004	API Endpoints	DDoS Attack	3	4	12	Rate limiting	DDoS mitigation, load balancing	Protect
R005	Employee Email	Phishing	5	3	15	Basic awareness training	Email filtering, MFA	Detect
R006	Cloud Storage	Misconfiguration	3	4	12	Basic access controls	Config audits, IaC	Protect
R007	Backup Systems	Backup Failure	2	5	10	Manual backups	Automated backup, offsite replication	Recover
R008	Network Infrastructure	Unauthorized Network Access	2	5	10	Firewall rules	Network segmentation, Zero Trust	Protect
R009	Third-party Vendors	Supply Chain Attack	2	5	10	Basic vendor agreements	Vendor security assessments, SLAs	Identify
R010	Incident Response	Slow Incident Detection	3	4	12	Manual monitoring	SIEM, automated alerting	Detect
R011	Data In Transit	Data Interception	3	5	15	SSL/TLS encryption	E2E encryption, cert pinning	Protect
R012	Admin Accounts	Privilege Escalation	2	5	10	Standard user privileges	PAM, PIM	Protect
R013	Compliance Records	Regulatory Non-compliance	2	5	10	Manual documentation	Automated compliance tracking	Govern
R014	Employee Offboarding	Access Not Revoked	3	4	12	Manual revocation	Automated deprovisioning, access reviews	Govern
R015	Disaster Recovery	Extended Downtime	2	5	10	Basic recovery plan	Tested DRP, redundant systems	Recover

L = Likelihood (1-5) | I = Impact (1-5) | Score = L × I | ■ High (15+) ■ Medium (10-14) ■ Low (<10)

5. Gap Analysis

The following analysis maps BrightPay Financial's current security posture against the six NIST CSF 2.0 functions, identifying where controls are missing or insufficient.

NIST Function	Expected Controls	Current State	Gap / Finding
Govern	Formal security policies, compliance tracking, risk governance program	No formal security policies documented. Compliance tracking is manual.	HIGH GAP — No security governance program exists. No risk committee. No documented policies for data handling, acceptable use, or incident response.
Identify	Asset inventory, risk assessments, vendor risk management	No formal asset inventory. No vendor security assessments.	MEDIUM GAP — BrightPay cannot fully protect what it cannot identify. Vendor risk is completely unmanaged despite reliance on third-party payment processors.
Protect	MFA, RBAC, encryption, endpoint protection, network segmentation	Basic password auth, basic antivirus, SSL/TLS in place. No MFA, no RBAC, no network segmentation.	HIGH GAP — Critical protection controls are missing. MFA and RBAC are baseline requirements for a payments processor. Absence creates significant breach risk.
Detect	SIEM, automated alerting, threat monitoring, log management	Manual monitoring only. No SIEM deployed.	HIGH GAP — Without automated detection, BrightPay cannot identify breaches in a timely manner. Mean time to detect (MTTD) is likely days to weeks, not hours.
Respond	Incident response plan, defined roles, communication procedures	No formal incident response plan documented.	MEDIUM GAP — Without a documented IR plan, response to a breach would be disorganized and slow, increasing damage and regulatory exposure.
Recover	Tested disaster recovery plan, automated backups, redundant systems	Manual backups. Basic recovery plan exists but untested.	MEDIUM GAP — An untested recovery plan is effectively no plan. Backup failure risk is high given manual processes.

Overall Maturity Assessment

BrightPay Financial currently operates at a **Tier 1 (Partial)** maturity level under NIST CSF 2.0. Risk management practices are informal and reactive. To reach **Tier 2 (Risk Informed)** maturity, the organization must implement the high-priority recommendations in this report within 90 days.

6. Recommendations & Remediation Plan

Recommendations are organized into three priority tiers based on risk score and potential business impact.

Tier 1 — Immediate Actions (0-30 Days)

1. Deploy Multi-Factor Authentication (MFA)

Enforce MFA for all admin accounts, payment system access, and remote employees immediately. This single control addresses R002, R005, and R012 simultaneously. Recommended solution: Microsoft Authenticator or Duo Security. Estimated effort: 1-2 weeks.

2. Implement Role-Based Access Control (RBAC)

Define and enforce least-privilege access roles for all systems. No user should have access beyond what their job function requires. Begin with payment processing system and customer database (R001, R002). Estimated effort: 2-3 weeks.

3. Deploy Endpoint Detection & Response (EDR)

Replace basic antivirus with an EDR solution (e.g., CrowdStrike Falcon, Microsoft Defender for Endpoint) on all employee laptops. Addresses R003. Estimated effort: 1 week.

Tier 2 — Short-Term Actions (30-90 Days)

4. Implement SIEM Solution

Deploy a Security Information and Event Management (SIEM) platform to centralize log collection and enable automated threat detection. Recommended: Microsoft Sentinel (integrates with existing Azure environment). Addresses R010. Estimated effort: 4-6 weeks.

5. Establish Vendor Risk Management Program

Require security questionnaires from all third-party vendors. Establish SLAs with security requirements. Addresses R009. Estimated effort: 3-4 weeks.

6. Automate Employee Offboarding Access Revocation

Implement automated deprovisioning workflows to immediately revoke access upon employee departure. Addresses R014. Integrate with HR system. Estimated effort: 2-3 weeks.

7. Document and Test Incident Response Plan

Create a formal IR plan with defined roles, communication procedures, and escalation paths. Conduct a tabletop exercise within 60 days of completion. Estimated effort: 3 weeks.

Tier 3 — Long-Term Actions (90+ Days)

8. Implement Privileged Access Management (PAM)

Deploy a PAM solution (e.g., CyberArk, BeyondTrust) to manage admin credentials, enforce just-in-time access, and create an audit trail for all privileged activity. Addresses R012.

9. Build Formal Security Governance Program

Establish a security policy library (Acceptable Use, Access Control, Data Classification, Incident Response), appoint a security officer, and implement a risk committee. Addresses R013 and overall Govern function gaps.

10. Implement Zero Trust Network Architecture

Transition from perimeter-based security to a Zero Trust model — verify every user, every device, every time. This long-term initiative addresses R008 and aligns with NIST SP 800-207.

7. Conclusion

This risk assessment reveals that BrightPay Financial faces meaningful cybersecurity risk across all six NIST CSF 2.0 functions. The organization's current security posture reflects an early-stage maturity level typical of small fintech companies that have prioritized growth over governance — a common but correctable situation.

The most critical finding is the absence of Multi-Factor Authentication and Role-Based Access Control on payment processing systems. For a company that handles customer financial data, these are not optional controls — they are baseline requirements under PCI-DSS and represent the minimum acceptable standard for any organization in the payments space. These must be addressed within 30 days.

The good news is that BrightPay's existing Azure infrastructure provides a strong foundation for rapid improvement. Microsoft Entra ID, Microsoft Defender, and Microsoft Sentinel can address a significant portion of the identified gaps within 90 days using tools BrightPay already has access to through its Azure subscription.

Next Steps

BrightPay Financial's leadership should take the following immediate steps following receipt of this report:

Priority	Action	Owner	Target Date
HIGH	Deploy MFA on all admin and payment system accounts	IT / Security Team	Within 30 days
HIGH	Implement RBAC across payment processing and customer database	IT / Security Team	Within 30 days
HIGH	Replace antivirus with EDR on all endpoints	IT Team	Within 30 days
MEDIUM	Deploy SIEM (Microsoft Sentinel recommended)	Security Team	Within 90 days
MEDIUM	Establish vendor security assessment process	Risk / Legal	Within 90 days
MEDIUM	Document and test Incident Response Plan	Security Team	Within 90 days
LOW	Build formal security governance and policy library	Security Officer	Within 6 months

Assessment prepared by: Prayash Bhattarai, Cybersecurity Analyst

Framework: NIST Cybersecurity Framework 2.0

Date: March 2026

Note: This assessment was conducted as a portfolio project using a fictional organization. All findings, risks, and recommendations are based on realistic fintech security scenarios and NIST CSF 2.0 guidelines.